POST-TEST : Uji Pemahaman SMKI — ISO/IEC 27001:2022

🛡️ Untuk melihat sejauh mana pemahaman kita mengenai penerapan Sistem Manajemen Keamanan Informasi (SMKI) berstandar ISO/IEC 27001:2022 di lingkungan kerja, Tim Pelaksana SMKI mengajak Rekan-rekan untuk mengikuti **Quiz Awareness SMKI**!

📝 **Sekilas tentang Quiz ini:**

- **Format:** 10 soal pilihan ganda & 4 soal uraian.
- **Topik:** Seputar risiko keamanan informasi, *Business Impact Analysis* (BIA), serta cara kita mengklasifikasikan aset dan sensitivitas data perusahaan sehari-hari.
- **Waktu Pengerjaan:** ⏱️ Sekitar 20 menit.

💡 **Penting untuk Diingat:** Hasil kuis ini **tidak akan memengaruhi penilaian kinerja** (KPI) Anda. Hasilnya murni akan kami gunakan sebagai bahan evaluasi untuk merancang program edukasi keamanan informasi yang lebih seru dan tepat sasaran ke depannya!Mohon kerjakan secara **jujur dan mandiri** (tanpa *browsing* atau melihat referensi ya) agar kami bisa memetakan *awareness* yang sebenarnya. 🧑‍💻✨
Terima kasih atas waktu dan partisipasi Anda.

Mari bersama-sama wujudkan lingkungan kerja yang aman dan peduli terhadap keamanan informasi! 💻

🔒 Salam, **Tim Pelaksana SMKI** 🔒

Masukan identitas Anda

1. Mohon informasikan Nama Anda *

2. Sebutkan Divisi / Departemen Anda *

- ◯ CEO Office
- ◯ Business Directorate - Special Project
- ◯ Business Directorate - Distribution Channel
- ◯ Business Directorate - Sales Office
- ◯ Business Directorate - Product Development
- ◯ Business Directorate - Business Services
- ◯ Operational Directorate - Operation
- ◯ Operational Directorate - Claim
- ◯ Operational Directorate - Client Services
- ◯ Technology & Information Directorate - Digital Solution Development
- ◯ Technology & Information Directorate - Information Technology Operation
- ◯ Technology & Information Directorate - Business Analyst
- ◯ Finance&Investment Directorate - Actuary
- ◯ Finance&Investment Directorate - Finance&Accounting
- ◯ Human Capital Directorate - Human Capital & General Affair
- ◯ Compliance Directorate - Legal & Compliance
- ◯ Compliance Directorate - Risk Management

Jawablah pertanyaan dengan pilihan yang tepat

3. Menurut UU PDP No. 27 Tahun 2022, siapa yang bertanggung jawab jika terjadi kebocoran data dari informasi pribadi karyawan di perusahaan Anda? * (5 Points)

- ◯ Hanya pengguna yang menangani data tersebut
- ◯ Pengontrol Data (Controller) adalah perusahaan, Pengolah Data (Processor) juga bisa ikut bertanggung jawab
- ◯ Hanya DPO (Data Protection Officer) yang bertanggung jawab
- ◯ D) Pengguna dan DPO berbagi tanggung jawab 50-50

4. Anda tahu ada data karyawan yang mungkin bocor dari email marketing yang kurang secure. ISO 27001:2022 Annex A.5.25 mengatur incident management. Kapan incident ini **HARUS** dilaporkan ke manajemen dan korban? * (5 Points)

- ◯ Dalam 30 hari setelah penemuan untuk memberikan waktu investigasi
- ◯ Dalam waktu yang dapat ditentukan perusahaan, minimal 3 bulan
- ◯ Segera/tanpa penundaan yang tidak perlu ketika ada indikasi kuat terjadinya incident
- ◯ Hanya jika data pribadi sensitif (nomor KTP, rekening bank), bukan data umum

5. Anda bekerja dari rumah dan menerima file penting company dari rekan Anda melalui WhatsApp personal. File tersebut berisi rencana strategi tahun depan. Apa yang **PALING SESUAI** dengan ISO 27001:2022 untuk perilaku Anda selanjutnya? * (5 Points)

- ◯ Simpan di Downloads folder laptop pribadi, beri password protected folder, dan hapus dari WhatsApp
- ◯ Meminta ulang untuk mengirimkan data tersebut melalui email resmi perusahaan dan meminta pengirim untuk menghapus data tersebut dari Whatsapp
- ◯ Segera download dan memindahkan ke sharing drive perusahaan yang encrypted
- ◯ Simpan di cloud personal storage (Google Drive/OneDrive pribadi) karena lebih aman dari device lokal

6. Menurut ISO 27001:2022, password policy yang paling **TIDAK DIREKOMENDASIKAN** adalah: * (5 Points)

- ◯ Minimal 12 karakter, kombinasi huruf besar, kecil, angka, simbol, ganti setiap 90 hari
- ◯ Minimal 8 karakter, kombinasi karakter, ganti setiap 180 hari ATAU jika ada anomali login terdeteksi
- ◯ Minimal 16 karakter untuk high-privilege, minimal 12 untuk user biasa, perubahan password saat ada suspect activity
- ◯ Minimal 8 karakter, ganti setiap 30 hari, pertanyaan keamanan sebagai backup authentication

7. Kolega Anda resign dan meminta copy data project tempat dia bekerja karena "untuk portfolio". Apa tindakan yang paling sesuai ISO 27001:2022 & UU PDP? * (5 Points)

- ◯ Berikan hanya ringkasan general (tanpa detail client/sensitive data) agar tidak terasa curiga
- ◯ Hubungi HR/manager untuk clarity tentang retention rights & confidentiality obligation setelah resign
- ◯ Berikan penuh karena data sudah dibuat kolega tersebut, dia punya right untuk portfolio
- ◯ Tolak langsung tanpa penjelasan karena "data perusahaan" = no

8. Rekan kerja share video meeting yang terlihat seperti CEO memberikan instruksi untuk transfer dana urgent ke rekening baru. Video terlihat natural dan menyakinkan. Apa yang HARUS dilakukan menurut awareness best practice ISO 27001:2022? * (5 Points)

- ◯ Langsung tanyakan ke CEO via email untuk confirm, forward video ke dia
- ◯ Hubungi CEO via telepon yang terdaftar/nomor dari employee directory SEBELUM mengambil tindakan finansial apapun
- ◯ Lihat video lagi dengan lebih teliti, kalau CEO-nya terlihat natural pasti genuine
- ◯ Tanya dulu ke finance team apakah ada instruksi transfer yang pending sebelum melakukan verification

9. Anda gunakan ChatGPT/Claude untuk analisis draft laporan keamanan internal yang berisikan: List sistem critical perusahaan, Kerentanan yang ditemukan audit, Remediation plan Apa risiko utama & tindakan yang PALING APPROPRIATE? * (5 Points)

- ◯ Risiko rendah selama hapus nama orang, banyak perusahaan pakai AI for productivity
- ◯ Hubungi security/DPO dulu sebelum paste data ke AI public, tanyakan approved vendor & data retention policy
- ◯ Pakai AI tapi anonymize nama sistem dan nominalize kerentanan, cukup safe untuk draft
- ◯ Pakai AI internal saja (kalau ada), jangan public AI tools

10. Perusahaan collect customer email untuk program loyalty. Program sudah berakhir 2 tahun lalu tapi email list masih tersimpan di marketing database. Menurut UU PDP & ISO 27001:2022, apa yang **HARUS** dilakukan? * (5 Points)

- ◯ Simpan terus untuk potential future marketing, customer data berharga untuk long-term value
- ◯ Delete segera tanpa verification, karena sudah tidak ada "lawful basis" untuk retain setelah program berakhir
- ◯ Assess retention necessity, update privacy notice, kalau tidak ada basis baru untuk retain → delete dengan bukti, dokumentasikan
- ◯ Anonymous data (samarkan informasi) dan simpan untuk historical analysis tanpa risk privacy violation

11. Karyawan develop aplikasi mobile sebagai part of job responsibilities menggunakan company resources (laptop, cloud platform, development tools). Setelah aplikasi launch sukses, karyawan claim: "Saya yang create, saya punya intellectual property right atas source code ini". Menurut HAKI, siapa pemilik RESMI? * (5 Points)

- ◯ Karyawan adalah pemilik (author = original creator), perusahaan hanya punya right to use
- ◯ Perusahaan pemilik penuh (work-made-for-hire), karyawan hanya punya moral right untuk attribution
- ◯ Shared ownership: Karyawan 60%, perusahaan 40% (resource contribution basis)
- ◯ Tergantung kontrak kerja - jika ada klausul IP assignment, perusahaan pemilik; jika tidak ada, karyawan pemilik

12. Saat audit keamanan informasi ditemukan :

- 50 SaaS applications (Slack, Notion, Monday.com, dll) dipakai teams tanpa IT approval
- 15 devices tidak registered dalam inventory (personal laptop dibawa pulang)
- 200+ cloud storage accounts (personal Google Drive, OneDrive shared folder dengan company data)

Menurut ISO 27001:2022 A.5.9 (Access control) & asset management, apa tindakan prioritas **PERTAMA**? * (5 Points)

- ◯ Shutdown semua unapproved apps immediately untuk enforce compliance, revoke akses
- ◯ Inventory everything, assess mana yang critical/risky, create approval process going forward, work with teams untuk transition
- ◯ Focus pada critical assets saja (database, email), untuk yang non-critical apps boleh tolerate
- ◯ Require all users delete personal cloud storage, provide approved tool alternative, enforce policy

Jawablah pertanyaan sesuai dengan kondisi yang ada pada Divisi/Departemen Anda

13. Sebutkan 3 jenis aset berdasarkan ISO 27001:2022 yang sering Anda gunakan beserta tingkat sensitivasnya! * (10 Points)

    Cara Menjawab menggunakan format:
    [Jenis Aset] - [Nama Aset Departemen] - [Sensitivitas Data] - [Kritikal/Non Kritikal]

    Contoh:

    1. Aset Informasi - Dokumen Xyz - Confidential - Kritikal
    2. Aset Hardware - Laptop - Confidential - Kritikal
    3. Aset Informasi - Dokumen Abc - Restricted - Kritikal

14. Sebutkan 2 jenis aset di perusahaan yang Anda tahu bersifat Confidential tetapi tidak bersifat Kritikal ! * (10 Points)

    Cara menjawab: Gunakan format seperti nomor sebelumnya

15. Dari aset-aset yang sudah Anda definisikan, sebutkan 3 jenis risiko yang mungkin terjadi pada aset-aset tersebut, apa saja ancaman dan mitigasinya.

    Cara Menjawab menggunakan format:
    [Nama Aset Departemen] - [Ancaman] - [Mitigasi] * (10 Points)

16. Business Impact Analysis (BIA) merupakan fondasi dari Business Continuity Management dan berkaitan erat dengan kontrol 5.30 (ICT readiness for business continuity) serta 5.29 (Information security during disruption) dalam Annex A ISO/IEC 27001:2022.
    Jelaskan:
    (a) Apa tujuan dibuatnya BIA?
    (b) Sebutkan 3 proses yang paling critical dari departemen Anda yang cocok dimasukkan dalam BIA * (20 Points)

This content is neither created nor endorsed by Microsoft. The data you submit will be sent to the form owner.

Microsoft Forms